

TradeVault

Synthese des 13 Audits (00-12)

Consolidation de tous les audits pre-funding pour avoir une vue unique
des actions necessaires avant le lancement.

Audit 00 — Repository Structure (Staff Engineer)
Audit 01 — Architecture (Staff Engineer)
Audit 02 — Performance (Staff Engineer)
Audit 03 — Securite (Security Engineer)
Audit 04 — Mobile (Mobile Lead)
Audit 05 — Architecture IA (AI Architect)
Audit 06 — UX/UI (UX Lead)
Audit 07 — Database (DBA)
Audit 08 — Fonctionnel (Product Manager)
Audit 09 — Production (Lead Engineer)
Audit 10 — Testing & Qualite (Staff Engineer)
Audit 11 — Technical Debt (Lead Engineer)
Audit 12 — Business (Founder)

1. Scoreboard Global

Scores sur 100 de chaque audit. La moyenne ponderee donne une vue d'ensemble de la maturite du projet.



Moyenne generale: 44.5/100

Interpretation: le projet a une base fonctionnelle mais necessite un travail structurel significatif avant d'etre pret pour le lancement public. Les points faibles sont l'architecture (36), les performances (36), et l'UX (39).

Classement des scores

- 01 Architecture: 36/100
- 02 Performance: 36/100
- 06 UX/UI: 39/100
- 05 Architecture IA: 40/100
- 10 Testing & Quality: 42/100
- 09 Production: 43/100
- 11 Technical Debt: 45/100
- 03 Securite: 46/100
- 07 Database: 46/100
- 04 Mobile: 47/100
- 12 Business: 50/100
- 00 Repository: 52/100
- 08 Fonctionnel: 56/100

2. Tous les issues CRITICAL / P0

AUDIT 01 — Architecture

- SSR crash garanti: generateId utilise crypto.randomUUID() indisponible en SSR
- Violation de la regle de layering: 8 imports modules -> app/
- Auth-middleware: getClaims() non implemente (lance Error)
- Migrations dupliquees: 20250613_checklist_v2.sql identique a v1
- FK manquante sur trades.account_id
- Delete-account: 13+ tables orphelines non nettoyees
- Infrastructure IA: 22 fichiers dont seulement 4 utilises
- Event Bus: fire-and-forget, pas de gestion d'erreur
- Aucun validateur d'entree (Zod non utilise sur les routes)
- Aucun timeout SSL ou request timeout sur les appels API

AUDIT 02 — Performance

- AI Provider: aucun timeout sur les appels fetch (blocage indefini)
- Import CSV: N+1 queries (insertion ligne par ligne)
- loadUserTrades: pas de pagination (charge tout d'un coup)
- select(*) dans trades, notifications, reports (colonnes inutiles)
- Tri redondant: trades tries cote serveur puis re-tries cote client
- ChecklistByDay: lit localStorage 20x par render
- Rapport mensuel cron: 20,000+ requetes pour 500 utilisateurs
- sendWebPush: sequentiel par destinataire (pas de Promise.all)
- 500 trades envoyes a chaque appel AI (cout inutile)

AUDIT 03 — Securite

- LocalStorage: tokens XSS-exposables (pas de httpOnly cookies)
- require-pro.ts: fail-open sur erreur DB (laisse passer sans verif)
- Delete-account: CORS wildcard + 15 tables orphelines
- sendPushToSelf: validateur no-op (accepte n'importe quoi)
- Prompt injection: aucune sanitisation des entrees utilisateur vers l'IA

AUDIT 04 — Mobile

- TradeDetailModal: pas de safe-area-bottom (notch iPhone)

AUDIT 05 — Architecture IA

- 0 business tools definis pour l'IA (aucune action possible)
- 0 proactivite: l'IA attend toujours une question
- Aucun tracking de cout (peut exploser sans alerte)
- Fire-and-forget: 50% des events IA jamais traites
- 500 trades envoyes a chaque appel (pousse la limite de contexte)
- Memoire non bornee: contextBuilder peut exploser en taille

AUDIT 06 — UX/UI

- Pas de routing URL: navigation non partageable
- Zero raccourcis clavier (accessibilite)
- lockZoom bloque l'accessibilite (interdit le zoom mobile)
- Pas de keyboard avoidance mobile (clavier cache les inputs)

AUDIT 07 — Database

- Pas de migration pour trades.account_id FK (donnees orphelines possibles)
- RLS owner-only non applique sur notifications, reports
- Aucun index sur les colonnes de jointure courantes
- Pas de partitionnement pour les tables a croissance rapide
- Seed data + migration dans le meme fichier

AUDIT 08 — Fonctionnel

- Pas de verification de compte (email non confirme = acces complet)
- Pas de reset de mot de passe fonctionnel
- Onboarding: pas de sauvegarde automatique (perte si refresh)

AUDIT 09 — Production

- Zero monitoring (pas de logs structure, pas de APM)
- AI timeout non configure (blocage utilisateur indefini)
- Aucun health check endpoint
- Free plan: limites non enforcees backend (contournable)
- RLS sur storage: risque de fuite de fichiers utilisateur
- Landing page 100% francaise (pas d'acquisition internationale)
- Pas de cookie consent banner (RGPD non conforme)
- Zero analytics (pas de tracking utilisateur)
- Pas de SEO (aucune balise meta, pas de sitemap)
- Pas de CI/CD (deploiement manuel)
- Pas de provider failover (si OpenAI down, tout l'AI Coach est mort)
- Aucun calcul de couts infrastructure

AUDIT 10 — Testing

- Zero test sur les pages, composants, hooks, backend (10 fichiers test seulement)
- Pas de test runner configure dans package.json
- Pas de test UI / integration / E2E
- Tests important par chemins relatifs fragiles

AUDIT 11 — Technical Debt

- AI Platform: ~40% scaffolding mort (~1200 lignes)
- Layer dependency violation: 8 sites modules -> app/
- Event Bus: fire-and-forget sans error handling
- i18n: Francais a 1023 cles, les 10 autres langues ~300 chacune

AUDIT 12 — Business

- Pricing invisible (pas de page dediee, pas de comparaison Free/Pro)
- Limites Free non enforcees backend
- Zero acquisition (pas de SEO, pas d'analytics, pas de contenu)

3. Plan d'Action Priorise

Tous les issues classes par priorite business et effort estime. Ce plan est concu pour etre execute par une equipe de 2-3 devs en 10 semaines.

Sprint 1-2: Fondations critiques (P0 must-fix)

- Fix SSR crash: remplacer crypto.randomUUID() par une alternative SSR-safe
- Fix auth-middleware getClaims(): implementer la methode ou remplacer par un middleware fonctionnel
- Fix Event Bus: ajouter try/catch autour de chaque handler, dead-letter queue
- Fix require-pro.ts: fail-closed (rejeter par default si erreur DB)
- Ajouter timeouts sur tous les appels fetch AI Provider (30s max)
- Fix migration duplquee et FK manquante sur trades.account_id
- Ajouter validateur d'entree Zod sur les routes API
- Implementer RLS owner-only sur notifications, reports, storage

Sprint 3-4: Securite & Performance

- Supprimer les tokens localStorage -> httpOnly cookies + refresh tokens
- Implementer pagination sur loadUserTrades
- Fix N+1 CSV import (batch insert)
- Supprimer les select(*) dans toutes les requetes
- Optimiser sendWebPush avec Promise.all
- Reduire le payload AI de 500 a ~50 trades max
- Sanitiser les entrees utilisateur pour l'AI Coach (anti-prompt-injection)
- Ajouter des index DB sur les colonnes de jointure

Sprint 5-6: Produit & UX

- Implementer le routing URL (navigation partageable)
- Ajouter keyboard shortcuts pour les actions frequentes
- Fix safe-area-bottom sur tous les modals (mobile)
- Ajouter keyboard avoidance sur les formulaires mobiles
- Sauvegarde automatique onboarding (evite perte sur refresh)
- Implementer la verification d'email et reset de password
- Compléter les ~7000 traductions manquantes (10 langues)
- Implementer proactivite AI Coach (notifications contextuelles)

Sprint 7-8: Infrastructure & Production

- Ajouter monitoring: logs structure + health check endpoint
- Implementer CI/CD (GitHub Actions: lint, build, test, deploy)
- Ajouter cookie consent banner (RGPD)
- Ajouter Google Analytics / PostHog (tracking utilisateur)
- Implementer SEO (balises meta, sitemap, i18n URLs)
- Ajouter provider failover AI (fallback si OpenAI down)
- Configurer les limites Free backend (hard blocks)
- Ajouter page de pricing publique

Sprint 9-10: Qualite & Dette Technique

- Supprimer les ~18 fichiers AI morts (scaffolding inutilise)
- Fix les 8 violations de layering (modules -> app/)

- Supprimer les 'as any' et @ts-ignore (14+ fichiers)
- Configurer Vitest + script de test + premiers tests
- Splitter les pages monolithiques (Checklist 2030I, Landing 1412I, Analytics 1102I)
- Remplacer les styles inline par les design tokens
- Renommer les fichiers dupliques (engine.ts x4, cn.ts x2, store.ts x2)
- Supprimer les console.log (20+ fichiers)
- Ajouter Error Boundary React + hierarchie d'erreurs

4. Quick Wins — Impact fort, effort faible

Fix require-pro.ts fail-open [Securite] Effort: 30 min

Changer 1 ligne: rejeter par default

Timeout AI fetch [Performance] Effort: 30 min

Ajouter AbortController.timeout(30000)

Fix generateId SSR [Architecture] Effort: 15 min

Remplacer crypto.randomUUID() par nanoid ou Date.now()

Select(*) suppression [Performance] Effort: 2h

Remplacer par colonnes nommees

Promise.all pour sendWebPush [Performance] Effort: 30 min

Envelopper dans Promise.allSettled

Limiter payload AI a 50 trades [Performance/Cout] Effort: 15 min

Ajouter .slice(-50) dans le context builder

Ajouter .gitignore pour .env [Securite] Effort: 15 min

Deplacement de .env, creation .env.example

Supprimer fichiers AI morts [Dette technique] Effort: 1h

Supprimer ~18 fichiers non importes

Ajouter index DB manquants [Performance] Effort: 1h

Migration additive avec CREATE INDEX

Supprimer console.log [Qualite] Effort: 2h

Remplacer par logger structure ou supprimer

5. Resume par Domaine

Architecture — 36/100 (rouge)

8 violations de layering, SSR crash, Event Bus non fiable, migrations dupliques, FK manquante, AI scaffolding mort. Le coeur du probleme: modules/ depend de app/ et l'Event Bus ne gere pas les erreurs.

Performance — 36/100 (rouge)

Requetes N+1, pas de pagination, select(*), tri redondant, payloads surdimensionnes. Le produit tient pour ~50 utilisateurs mais cassera a 500+.

Securite — 46/100 (orange)

Tokens en localStorage (XSS), fail-open sur paypal, prompt injection, CORS wildcard. La securite est utilisable mais pas industrialisable.

Mobile — 47/100 (orange)

Safe-area manquant, pas de keyboard avoidance, lockZoom bloque l'accessibilite. L'experience mobile est fonctionnelle mais frustrante.

IA — 40/100 (orange)

Architecture IA solide sur le papier mais 40% de scaffolding mort, 0 proactivite, 0 outils, pas de tracking de cout. L'AI Coach est reactif et basique.

UX/UI — 39/100 (rouge)

Pas de routing URL, pas de raccourcis, lockZoom, pas de keyboard avoidance. L'interface est jolie mais pas professionnelle.

Database — 46/100 (orange)

RLS incomplete, index manquants, pas de partitionnement, seed+migration melanges. La DB tient mais ne passera pas a l'echelle.

Fonctionnel — 56/100 (vert)

43 issues dont 3 critiques. 16 fonctionnalites pretes, 10 partielles, 25 manquantes. Le produit a le perimetre minimum mais des trous notables (verif email, reset pwd).

Production — 43/100 (orange)

12 launch blockers absolus: monitoring zero, AI timeout, pas de CI/CD, pas de limites Free backend, pas de RGPD, pas de SEO, pas d'analytics.

Testing — 42/100 (orange)

10 fichiers test seulement, 4.8% coverage, pas de UI/integration/E2E, pas de test runner configure. Le produit n'a quasiment pas de filet de securite.

Technical Debt — 45/100 (orange)

40% code IA mort, 8 violations layering, ~7000 traductions manquantes, 14 fichiers avec suppressions TS, pages monolithiques de 2000 lignes.

Business — 50/100 (orange)

Probleme reel, marche sizable, mais acquisition zero, pricing invisible, limites Free contournables, pas de metriques. Le produit必须先 trouver ses premiers users.

6. Conclusion & Prochaine Actions

Ce document consolide 13 audits realisation par 8 roles differents. La moyenne de 44/100 refilete un projet en phase pre-seed: fonctionnel mais pas industrialisable en l'etat.

Les 5 priorites absolues avant tout lancement

1. FIX SSR CRASH ET AUTH — Le produit ne doit pas planter au chargement
2. FIX EVENT BUS — Les donnees ne doivent pas etre perdues silencieusement
3. FIX SECURITE — Tokens, RLS, fail-open: des failles exploitables
4. AJOUTER MONITORING — Sans logs ni metriques, vous etes aveugle
5. LIMITES FREE BACKEND — Sans hard blocks, pas de conversion

Les 5 priorites business pour trouver des clients

1. PAGE PRICING + ESSAI GRATUIT — L'utilisateur doit savoir ce qu'il gagne en payant
2. AI COACH PROACTIF — La seule vraie differenciation du produit
3. SEO + LANDING PAGE INTERNATIONALE — Sans trafic, pas de clients
4. ANALYTICS METIER — Mesurer pour piloter
5. COMMUNAUTE — Les traders parlent aux traders. Bouche-a-oreille = canal principal

Prochaine etape: implementer les quick wins (Sprint 1-2)

puis attaquer les P0 des audits dans l'ordre du plan d'action.